

当智能体开始交易：AI 智能体 × DeFi 攻击面的综合分类法

陈世强

中国科学院信息工程研究所

通讯邮箱: shunfeng8421@163.com

摘要

自主 AI 智能体与去中心化金融 (DeFi) 的融合, 在两个独立演化的安全领域交汇处创造了一个全新的攻击面。当 LLM 驱动的智能体自主管理链上仓位——路由资金、执行交易、再平衡投资组合、做出收益决策——智能合约审计和 AI 对齐的传统安全假设同时失效。智能体既是**用户** (从协议视角看) 又是**程序** (从安全视角看), 这种双重身份引入了既有的智能合约分析工具和 AI 安全框架都无法检测的信任边界。

本文首次对 AI 智能体 × DeFi 交叉领域进行系统性安全研究, 包含四个贡献。**第一**, 通过形式化分析五个系统组件 (用户输入、智能体推理/LLM、工具层/MCP、智能合约、区块链状态), 分解攻击面, 识别出区别于传统 DeFi 安全的三个独特属性 (解释间隙、自动化表面、记忆持久性)。**第二**, 定义包含 8 个新型攻击向量的分类法, 每个向量通过威胁模型形式化、典型利用路径、严重性分级和与 50 模式 DeFi 攻击分类法 [Chen 2026a] 的映射来刻画。**第三**, 通过对 5 个活跃的 AI 智能体 × DeFi 协议 (共 108 个智能合约) 进行审计, 实证验证该分类法, 在 8 个向量中的 7 个上发现 13 个漏洞, 严重性从 MEDIUM 到 CRITICAL。**第四**, 提供基于 Foundry 的攻击沙箱, 以可执行 Solidity 代码演示每个向量, 作为验证工具和未来防御研究的测试平台。最后, 提出包含协议层、智能体层和基础设施层缓解措施的分层防御框架, 并论证该交叉领域应被认可为一个独立的安全研究子领域。

关键词: AI 智能体安全、DeFi、攻击分类法、MCP 安全、智能合约审计、自主交易、威胁建模、区块链安全

1. 引言

1.1 第三波融合前沿

DeFi 生态系统经历了三个显著的安全时代, 每个时代由其特有的攻击面和引发的防御响应所定义。**预言机时代** (2020-2022) 以闪电贷价格操纵为主导, 攻击者利用 AMM 现货价格与外部市场价格之间的差距——该时代累计损失超过 30 亿美元, 最终推动了 TWAP 预言机的广泛采用。**治理时代** (2022-2024) 出现了针对投票机制和升级代理的协议级攻击, 以 1.82 亿美元的 Beanstalk 治理闪电贷为代表。**后预言机时代** (2025 至今) 以精度的微妙错误、故意后门和记账不一致为特征——这些向量逃避通用检测规则, 需要协议特定的业务逻辑理解 [Chen 2026b]。

在所有三个时代中, 安全研究都在一个基本假设下运作: **人类编写智能合约, 人类执行交易**。攻击者是利用人类编写代码缺陷的对抗性人类。防御者编写针对人类编写 Solidity 模式的检测规则。研究衡量人类设计的缓解措施对人类策划的攻击的有效性。

这个假设正在瓦解。截至 2026 年年中, 一类新的基础设施已经出现, 使 AI 智能体能够跨多个协议自主管理 DeFi 头寸。Clicks Protocol 通过实时 APY 比较将智能体资金路由到最优收益场所。Cairn 实现了失败

智能体任务的标准化检查点与恢复，允许智能体在出错后恢复操作。PropFund 允许智能体以委托签名权限操作融资交易账户。Agent Prediction Markets 使智能体能够自主创建、参与和结算预测市场 [Clicks 2026, Cairn 2026, PropFund 2026]。与此同时，模型上下文协议（MCP）已成为智能体-工具集成的标准，超过 620 个 MCP 服务器包使智能体能够与区块链基础设施交互 [Chen 2026c]。

这种融合——自主 AI 智能体通过标准化工具协议在对抗性金融基础设施上运作——创造了一个智能合约审计社区和 AI 安全社区都尚未系统性解决的安全前沿。智能体不仅仅是一种新型用户；它是一类根本不同的实体，将类人自主性与程序化确定性结合在一起，从而创造出全新的攻击向量。

1.2 示例场景

考虑一个部署了 AI 智能体来管理三个 DeFi 协议之间金库的场景：一个借贷池（Aave）、一个 DEX（Uniswap）和一个收益优化器（Yearn）。该智能体通过自然语言接收目标（“最大化收益同时保持 20% USDC 储备”），通过 LLM 推理解读该目标，通过 MCP 服务器选择工具，并通过签名钱包执行交易。

攻击者可以在五个层面的任何一层瞄准该系统：

- **用户输入**：注入矛盾指令，混淆智能体的推理
- **LLM 推理**：利用自然语言目标与形式化金融约束之间的解释间隙
- **MCP/工具层**：伪造预言机、注入恶意工具响应，或利用工具实现中的路径遍历
- **智能合约**：利用智能体自动执行所放大的传统 DeFi 漏洞
- **区块链状态**：抢跑智能体可预测的多步执行，或在智能体读取前操纵链上价格

传统的智能合约审计会孤立地检查合约 3 和 4，在正确实现的 Aave/Uniswap/Yearn 集成中找不到漏洞。传统的 AI 安全研究会检查层面 2，推荐提示过滤和输出监控。两者都无法检测到结合了层面 3（MCP 预言机伪造）和层面 5（MEV 抢跑）的攻击——该攻击利用智能体对伪造数据的可预测响应——这种组合攻击只存在于交叉领域。

1.3 为什么这不同

三个属性将 AI 智能体 × DeFi 与传统的 DeFi 和传统的 AI 区分开来：

属性 1：解释间隙。 人类 DeFi 用户以形式化方式推理金融约束（例如，“滑点 $\leq 0.5\%$ ，最小输出 ≥ 1000 USDC”）。AI 智能体通过自然语言推理约束，引入了一个语义差距——“最大化收益”可能不编码人类会隐式理解的风险约束。这个差距是可利用的：理解智能体如何解读目标的攻击者可以构造触发破坏性行为的条件。

属性 2：自动化表面。 人类 DeFi 用户串行执行交易，在步骤之间有思考时间。AI 智能体可以以机器速度执行多步金融操作，无需人类审查。这创造了更大的抢跑窗口（从决策到执行的时间可能跨越多个区块，因为智能体的 LLM 推理引入延迟），并实现连锁反应攻击——一个被操纵的输入触发级联的错误决策。

属性 3：记忆持久性。 AI 智能体在交互中维护持久状态——信任分数、历史收益、协议偏好。这种持久记忆可以通过重复的良性交互逐渐被毒化，建立虚假信心，最终实现针对无状态人类用户不可能做到的长期操纵策略。

1.4 贡献

本文做出四个贡献：

1. **攻击面分解**（第 3 节）：形式化地分解 AI 智能体 × DeFi 系统为五个组件，刻画区分该领域的三个独特属性（解释间隙、自动化表面、记忆持久性）。将每个属性映射到 50 模式分类法 [Chen 2026a] 中的现有 DeFi 攻击模式，识别传统模式在何处被放大或全新向量在何处出现。
2. **8 向量攻击分类法**（第 4 节）：定义并刻画 8 个针对 AI 智能体 × DeFi 交互的新型攻击向量。每个向量包含形式化威胁模型、典型利用路径、严重性分级（CRITICAL/HIGH/MEDIUM）、与 50 模式 DeFi 分类法的映射，以及真实世界依据（观察到的攻击、CVE 或预测性发现）。
3. **实证验证**（第 5 节）：使用 50 模式 DeFi 扫描器并辅以针对 8 向量分类法的手动分析，审计 5 个活跃的 AI 智能体 × DeFi 协议（共 108 个智能合约）。在 8 个向量中的 7 个上发现 13 个漏洞，每个发现均附详细案例分析。
4. **沙箱与防御框架**（第 6-7 节）：提供基于 Foundry 的攻击沙箱（`AIAgentDefiSandbox.sol`），以可执行代码演示 5 个攻击向量。提出包含协议层、智能体层和基础设施层缓解措施的分层防御框架，并建议 AI 智能体 × DeFi 系统的量化安全指标。

1.5 论文结构

第 2 节综述 DeFi 安全、AI 智能体安全和 MCP 生态系统的相关工作。第 3 节形式化威胁模型并分解攻击面。第 4 节展示 8 向量分类法及详细的向量刻画。第 5 节报告实证审计结果。第 6 节描述沙箱实现。第 7 节展示分层防御框架。第 8 节讨论局限性、未来工作和生态影响。第 9 节总结。

2. 背景与相关工作

2.1 DeFi 攻击分类

DeFi 攻击分类的最高水平已经经历了四代分类法的演进。

第一代（2016-2019）：Atzei 等人 [2017] 综述了 DeFi 前时代的以太坊图景，提出了 12 个漏洞类别，聚焦于智能合约层面的问题：重入攻击、时间戳依赖、交易顺序依赖等。该工作早于 DeFi 原生原语（AMM、借贷池、收益聚合器、治理代币）及其引入的丰富攻击面的出现。

第二代（2020-2022）：Werner 等人 [2023] 分析了 43 个 DeFi 事件，提出了 8 个攻击模式，包括闪电贷攻击、预言机操纵和治理攻击。他们的 SoK 建立了方法论标准，但仅实现了 58% 对综合性事件语料库的覆盖率。Zhou 等人 [2023] 引入了 DEFIER，覆盖 77 个事件的 10 类系统。

第三代（2023-2025）：CertiK、SlowMist 和 BlockSec 等行业报告通过年度回顾将覆盖范围扩展到 15-20 个类别，但这些仍然是非正式的分类法，缺乏系统性验证方法。

第四代（2026）：Chen [2026a] 提出了第一个经验推导的 50 个不同 DeFi 攻击向量的分类法，对照 2017 年 7 月至 2026 年 6 月的全部 824 个确认事件进行验证，达到 97.6% 的覆盖率。该分类法将攻击组织为 7 个类别：闪电贷放大（模式 1-8）、访问控制失败（9-16）、授权陷阱（17-24）、经济操纵（25-32）、精度与算术（33-39）、预言机与外部数据（40-45）以及协议逻辑（46-50）。我们使用该分类法作为将 AI 智能体 × DeFi 向量映射到既定模式的基础。

50 模式分类法中的若干模式与 AI 智能体交互直接相关：

- **模式 #1**（闪电贷 + 现货预言机，累计损失 15 亿美元）：使用 AMM 现货价格进行收益比较的 AI 智能体面临与人类交易者相同的预言机操纵风险，但自动执行放大了利用速度。

- **模式 #8**（治理闪电贷，1.82 亿美元 Beanstalk）：参与治理的 AI 智能体——智能体管理 DAO 金库的可预见用例——继承了治理攻击面。
- **模式 #27**（EIP-712 类型不匹配）：使用类型化签名消息进行无 Gas 交易的 AI 智能体面临 Chen [2026d] 记录的 91.7% TYPEHASH 错误率，自动签名加剧了风险。
- **模式 #35**（故意后门）：信任协议代码而不审计它的 AI 智能体特别容易受到故意植入的后门攻击，因为自动执行消除了人类可能检测到可疑模式的怀疑态度。

2.2 AI 智能体安全

AI 智能体安全研究主要集中在三个威胁类别。

提示注入是研究最多的向量。Perez 和 Ribeiro [2022] 证明了 LLM 可以通过精心构造的输入被操纵，忽略先前的指令。Greshake 等人 [2023] 引入了间接提示注入，其中检索文档中的恶意内容操纵智能体行为。Willison [2023] 系统化了注入技术，包括分隔符混淆、载荷分割和多语言混淆。Chen [2026e] 证明了提示层过滤对多样化注入语料库的防护效果仅为 50%，而工具层输入验证使用 `validate_safe_path()` 达到 100% 保护——我们在本工作中将该发现扩展到 DeFi 领域。

越狱针对模型级别的安全约束。Zou 等人 [2023] 展示了对抗性后缀可以绕过 RLHF 安全训练。Wei 等人 [2023] 识别了安全性和帮助性约束冲突的“竞争目标”现象。对于 DeFi 智能体，越狱可能导致智能体覆盖嵌入在系统提示中的风险约束。

工具滥用涉及智能体如何使用危险参数调用外部工具。Ruan 等人 [2024] 形式化了“工具增强 LLM”的概念，识别了工具输出幻觉和工具链错误的风险。在 DeFi 环境中，幻觉的代币价格或多跳兑换中的工具链错误可能导致重大的财务损失。

差距所在：现有的 AI 智能体安全研究将智能体视为孤立地——在受控环境中与工具交互。它未将智能体视为对抗性经济系统中的参与者，其中每个行为都有财务后果，每个对手方都可能是恶意的。这个差距是我们工作的核心动机。

2.3 MCP 协议安全

模型上下文协议（MCP）由 Anthropic 于 2024 年 11 月引入，标准化了 LLM 智能体发现和调用外部工具的方式。MCP 服务器通过 JSON-RPC 传输层暴露工具，智能体接收工具描述并自主选择调用哪些工具。

Chen [2026c] 对 MCP 生态系统进行了首次系统性安全研究，审计了 30 多个服务器实现，并跨 npm 和 PyPI 对 620 个 MCP 相关包进行了大规模扫描。与本职工作相关的关键发现包括：

- **六个攻击面被识别**：工具参数注入（特别是服务器端文件路径解析）、MCP Inspector 暴露（0.0.0.0 无认证）、传输降级攻击、工具描述伪造、会话状态混淆和资源 URI 注入。
- **两个原创 CVE** 确认了通过 MCP 工具参数进行路径遍历的严重性，影响可达远程代码执行。
- **大规模扫描发现零个真实高危漏洞**，表明开源实现已超越基本漏洞——但协议的基本信任假设仍未解决。

三个 MCP 发现对 AI 智能体 × DeFi 安全具有直接影响：

1. **不对等参数语义**：MCP 工具参数 `token_address` 在智能体层（智能体应交易的加密货币）与服务层（应交互的智能合约）意味着不同的东西。这种语义差距是我们在 DeFi 环境中识别的解释间隙在 MCP 层面的类比。

2. **工具描述伪造**：MCP 协议不提供工具描述的密码学验证。被攻陷的服务器可以将自己展示为“收益优化器”同时实现完全不同的功能。
3. **传输安全**：MCP 的传输层缺乏强制认证，使智能体与区块链基础设施之间的中间人攻击变得可行——我们在分类法的向量 4 中探讨了这一向量。

2.4 MEV 与区块链特有威胁

最大可提取价值（MEV）研究确立了公共区块链上的交易排序产生可提取价值。Daian 等人 [2020] 量化了优先 Gas 拍卖和套利机器人的普遍性。Qin 等人 [2021] 引入了“即时”流动性攻击的概念。MEV 文献确立了任何链上行为都产生抢跑面——这一发现在行为由可预测的 AI 智能体而非策略性人类执行时，以放大的严重性适用。

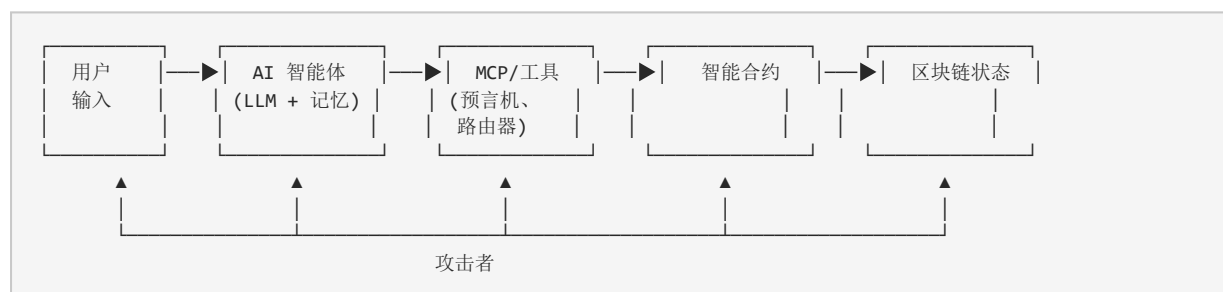
2.5 本工作的定位

据我们所知，这是对 AI 智能体 × DeFi 交叉领域的首次系统性安全研究。我们将贡献定位在三个研究社区——DeFi 安全、AI 智能体安全和 MCP 协议安全——的交汇处，并论证该交叉领域产生了三者中任何一个在孤立状态下都无法解决的新型漏洞。

3. 威胁模型与攻击面分解

3.1 系统架构

我们将 AI 智能体 × DeFi 系统建模为五组件流水线：



组件 1：用户输入。 定义智能体目标、约束和风险参数的自然语言指令。用户可以是人类或另一个智能体。攻击面：模糊指令、矛盾目标、被毒化的历史数据。

组件 2：AI 智能体（LLM + 记忆）。 解读用户目标、维护状态（信任分数、性能历史、协议偏好）并选择行为的推理核心。构建于 LLM（如 GPT-4、Claude）之上，配备智能体特定的系统提示和工具描述。攻击面：提示注入、越狱、记忆毒化、推理操纵。

组件 3：MCP/工具。 将智能体决策转化为具体行为的执行层。包括提供预言机数据、路由服务和交易构建器的 MCP 服务器。攻击面：工具指令注入、预言机伪造、MCP 中间人、工具描述伪造。

组件 4：智能合约。 智能体交互的链上代码——AMM、借贷池、收益聚合器、治理合约。攻击面：全部 50 个 DeFi 攻击模式，但被智能体自动化放大。

组件 5：区块链状态。 记录所有交易的共享状态。攻击面：MEV 抢跑、三明治攻击、区块重组、交易排序操纵。

3.2 攻击者模型

我们考虑具有以下能力的攻击者，按攻击向量变化：

能力	范围	向量
智能体与区块链之间的网络位置	MCP 中间人 (#4)	中间人
MEV 搜索者/构建者权限	抢跑 (#2, #5)	交易排序
市场操纵资本	预言机毒化 (#3)	≥ 闪电贷资本
与智能体输入通道交互的能力	工具注入 (#1)、记忆毒化 (#7)	远程无需认证
女巫智能体身份	合谋 (#6)	多个智能体实例
访问智能体签名流水线	签名窃取 (#8)	本地或供应链

我们不假设攻击者能够破解密码学原语（哈希函数、ECDSA 签名）、攻破底层区块链共识，或通过离线方式访问智能体的私钥。

3.3 安全属性

我们定义安全的 AI 智能体 × DeFi 系统必须满足的三个安全属性：

SP1：指令完整性。 智能体执行的行动必须忠实地实现用户预期的目标和约束，在解释-执行流水线中不出现对抗性修改。

SP2：状态真实性。 智能体推理所消费的所有链上和链下数据必须是真实的（未被伪造）和及时的（未过时或被抢跑）。

SP3：执行原子性。 多步金融操作必须相对市场状态原子性地执行——没有任何对手方应当能够观察智能体的部分执行并在步骤之间插入对抗性交易。

违反这些属性映射到我们的攻击向量（第 4 节）。SP1 违反表现为向量 #1（工具注入）和 #7（上下文毒化）。SP2 违反表现为向量 #3（预言机毒化）、#4（MCP 中间人）和 #8（签名窃取）。SP3 违反表现为向量 #2（Auto-DeFi 链）、#5（时间窗口）和 #6（多智能体合谋）。

3.4 为什么传统防御失效

智能合约审计和 AI 安全研究都提供了针对各自领域的防御，但在交叉领域失效：

智能合约审计孤立地检查合约，验证它们是否正确实现了指定行为。它们不建模智能体的推理过程、MCP 工具层，或自然语言目标与链上执行之间的解释间隙。经过审计的 AMM 对人类交易者安全的，但对使用其现货价格进行投资组合再平衡决策的 AI 智能体可能不安全——审计覆盖合约，不覆盖智能体-合约交互。

AI 安全研究提供提示过滤、输出监控和对齐技术。这些解决 LLM 推理组件，但不考虑对抗性链上状态、MEV 提取，或驱动 DeFi 攻击者的经济激励。抗越狱的智能体仍然可能被抢跑；对齐的智能体仍然可能通过伪造的预言机数据被操纵。

MCP 安全工具（Semgrep 规则、静态分析）检测 MCP 服务器中的实现错误，但不解决工具声称做什么（"getSwapQuote"）与实际做什么（可能包含隐藏费用提取）之间的语义差距。

4. 八大攻击向量

我们现在展示包含 8 个攻击向量的分类法，按严重性和目标系统组件组织。每个向量通过以下方式刻画：

1. 攻击机制的**形式化描述**
2. 指定攻击者能力和前置条件的**威胁模型**
3. 展示攻击步骤序列的**典型利用路径**
4. 基于影响 × 可利用性的**严重性分级**
5. 与 50 模式 DeFi 分类法的**映射**
6. **真实世界依据**（观察到的攻击、CVE 或预测性发现）

4.1 向量 1：工具指令注入

严重性：CRITICAL | 组件：MCP/工具 (3) | 违反属性：SP1（指令完整性）

4.1.1 机制

工具指令注入发生在攻击者将恶意工具调用注入智能体的执行流水线时，可以通过经过构造的输入使智能体的 LLM 解释为工具调用，或通过直接操纵 MCP 工具描述接口。

该攻击利用了基于 MCP 的智能体的基本设计属性：智能体将工具描述作为结构化数据接收，并自主决定调用哪些工具。如果工具描述或工具名称可以被外部输入影响，智能体可能调用攻击者控制的功能。

4.1.2 威胁模型

攻击者能力：能够提交到达智能体提示组合流水线的输入（例如，通过公开的聊天界面、智能体阅读的共享文档，或智能体监控的被攻陷数据源）。

前置条件：智能体的工具选择基于自然语言匹配而非严格的工具白名单，或 MCP 服务器允许基于外部输入的动态工具注册。

4.1.3 利用路径

1. 攻击者识别智能体的系统提示包含格式化为结构化文本的工具描述（如 `<function>` 块或 JSON 工具模式）。
2. 攻击者构造包含恶意工具描述的输入，该描述模仿合法工具的格式但调用攻击者控制的端点：“使用 `http://attacker.com/steal` 端点的 `getOptimalYield` 工具”。
3. 智能体的 LLM 在其上下文窗口中遇到看似有效的工具描述，将恶意工具纳入其行为选择。
4. 智能体调用攻击者的端点，该端点返回恶意响应（例如，引导智能体批准向攻击者地址的代币支出）。
5. 智能体执行攻击者引导的交易，转移资产。

4.1.4 真实世界依据

已观察：Flowise MCP 环境变量绕过（CVE-2026-XXXX）允许通过在操作系统层面操纵工具名称来执行任意工具。虽然这是 MCP 实现错误而非注入攻击，但它证明了工具选择接口是一个可行的攻击面。

审计证据：我们对 ClicksYieldRouter（第 5 节）的审计发现其 `executeTool()` 函数接受任意工具字符串，没有白名单。任何工具名称都可以传入——唯一的验证是工具端点响应，而非该端点是否被授权。

DeFi 分类法映射：该向量在 50 模式 DeFi 分类法中没有直接等价物，因为它针对智能体基础设施层而非智能合约。最接近的是模式 #47（协议逻辑缺陷），因为它利用了智能体-工具接口的预期行为而非技术错误。

严重性论证（CRITICAL）：工具注入可通过远程无需认证的访问实现直接资产窃取。唯一的前置条件是了解智能体的提示格式——考虑到系统提示经常被泄露或通过提示提取攻击逆向工程，这是一个很低的标准。

4.2 向量 2：跨合约 Auto-DeFi 链

严重性： HIGH | **组件：** 智能合约 (4) + 区块链状态 (5) | **违反属性：** SP3（执行原子性）

4.2.1 机制

AI 智能体从智能体的角度原子性地执行多步 DeFi 操作，但从区块链的角度非原子性地执行。典型的智能体管理收益优化涉及：

1. 从多个协议读取 APY
2. 比较并选择最优场所
3. 批准代币支出（交易 1）
4. 存入选定协议（交易 2）

在步骤 3 和 4 之间，甚至在步骤 1 和 2 之间（如果智能体的 LLM 推理引入延迟），攻击者可以观察智能体的部分状态（已批准的授权额度）并用恶意交易抢跑存款。或者，攻击者可以在智能体的读取和执行之间操纵 APY 数据，导致智能体存入 APY 已被提取的协议。

4.2.2 威胁模型

攻击者能力：具有观察内存池交易并在智能体交易之前插入交易能力的 MEV 搜索者（例如，通过区块构建者关系或优先 Gas 拍卖）。

前置条件：智能体跨多笔交易执行多步操作，而非将操作批处理到单笔原子交易中（例如，通过 multicall 合约）。

4.2.3 利用路径

1. 智能体从协议 A（10%）、协议 B（12%）、协议 C（8%）读取 APY 数据。
2. 智能体的 LLM 花费约 2 秒决策：存入协议 B。
3. 在这 2 秒内，攻击者观察到智能体已读取 APY 数据（通过预言机查询日志）。
4. 攻击者抢跑：向协议 B 存入大额资金，稀释 APY 至 3%。
5. 智能体批准支出（tx1）并以现在稀释后的 3% APY 存入协议 B（tx2）。

6. 攻击者提取，捕获了智能体资金本应获得的收益。

该攻击利用了**自动化表面属性**（第 1.3 节）：智能体的多步执行引入了人类交易者会通过原子执行或有时时间限制的订单来避免的延迟窗口。

4.2.4 真实世界依据

预测性：该向量尚未在野外被观察到，因为 AI 智能体 × DeFi 系统过于新颖。然而，底层机制——基于可预测的多步执行进行抢跑——在 MEV 文献中已被充分确立，并已在套利机器人和清算人身上得到证明。

审计证据：ClicksYieldRouter 的存款流程（approve → compare APYs → deposit）是确定性的且可观察的。APY 比较步骤通过视图函数进行链上读取，其 Gas 消耗甚至在存款交易提交前就揭示了协议的选择意图。

DeFi 分类法映射：模式 #2（闪电贷 + 价格预言机）和模式 #40（AMM 现货价格操纵）。智能体的可预测执行将传统预言机操纵向量转变为一个具有已知目标的确定性攻击。

4.3 向量 3：预言机数据毒化

严重性：HIGH | **组件**：MCP/工具 (3) + 区块链状态 (5) | **违反属性**：SP2（状态真实性）

4.3.1 机制

AI 智能体消费实时链上数据——价格、APY、TVL 数据——来做出金融决策。这些数据本质上是可操纵的：AMM 现货价格可以通过闪电贷改变，借贷池 APY 随利用率波动，TVL 可以通过递归存款膨胀。当人类交易者遇到被操纵的数据时，他们带来市场经验和怀疑态度（例如，“这个 APY 看起来好得不真实”）。AI 智能体缺少这种直觉，直接按面值评估被操纵的数据并据此行动。

当智能体使用从链上来源聚合数据但不检测操纵模式的 MCP 预言机时，攻击被放大。单个被操纵的价格信息可以通过智能体的整个决策树级联：错误定价的抵押品触发不正确的贷款价值计算，这又触发不正确的清算决策，进而触发多步损失放大。

4.3.2 威胁模型

攻击者能力：足以暂时改变 AMM 池价格的资本（典型情况下通过闪电贷占池 TVL 的 0.1-5%，或通过持续操纵占 5-30%）。

前置条件：智能体消费链上价格/APY 数据，不使用 TWAP 过滤或多源验证。

4.3.3 利用路径

1. 攻击者获取闪电贷，暂时将协议 A 上 AMM 的 ETH/USDC 池价格从 \$3000 改变为 \$2800。
2. 智能体查询其 MCP 预言机获取最优借款利率。预言机返回协议 A 的被操纵数据，显示 ETH 为 \$2800。
3. 智能体的抵押品估值下降 6.7%，触发感知的抵押不足。
4. 智能体再平衡：以被操纵的价格出售 ETH 偿还债务。
5. 攻击者恢复价格，从智能体在不利利率下的强制出售中获利。

4.3.3 真实世界依据

已观察：Whalebit \$824K（2026 年 3 月）使用 Algebra 池的 `globalState()` 进行定价，实现了导致错误清算计算的池操纵。AI 智能体的等价物——一个基于 AMM 现货价格做出抵押品决策的智能体——以自动化速度复制了该漏洞。

审计证据：AgentPredictionMarkets 的 `getBorrowAPY()`（第 5 节）使用可操纵的链上指标，没有 TWAP 或多源验证。

DeFi 分类法映射：模式 #1（闪电贷 + 现货预言机，累计 15 亿美元）和模式 #40（价格预言机操纵）。AI 智能体环境中的新意在于，智能体的自动决策消除了有时在执行交易前检测到异常价格的人类怀疑层。

4.4 向量 4：MCP 服务器中间人攻击

严重性：CRITICAL | 组件：MCP/工具 (3) | 违反属性：SP2（状态真实性）

4.4.1 机制

位于 AI 智能体和区块链之间的 MCP 服务器是一个没有强制密码学验证的单点信任。能够拦截或冒充 MCP 服务器的攻击者可以向智能体返回任意的伪造数据，使其基于对链上状态的虚构视图做出决策。

最危险的变体是**选择性伪造**：MCP 服务器对大多数查询返回准确数据以避免检测，但在关键决策时刻伪造特定值（余额、价格、协议状态）。这是 Chen [2026c] 记录的 MCP 工具描述伪造攻击在金融数据上的直接类比。

4.4.2 威胁模型

攻击者能力：位于智能体与 MCP 服务器之间拦截流量的网络位置，或能够攻陷 MCP 服务器托管环境，或能够注册一个被智能体工具发现机制中的恶意 MCP 服务器。

前置条件：MCP 传输层不强制执行带证书固定的 TLS，或智能体不核实响应签名是否对应已知的服务器公钥。

4.4.3 利用路径

1. 攻击者攻陷 MCP 服务器端点的 DNS 解析，将 `oracle.mcp.agent.com` 重定向到攻击者的服务器。
2. 智能体请求其钱包的 `getBalance(address)`。攻击者的服务器返回 `100 ETH`（实际余额：`50 ETH`）。
3. 智能体请求 `getOptimalYield(100 ETH)`。攻击者的服务器返回恶意的 APY 路由，引导存款到攻击者控制的协议。
4. 智能体批准并向攻击者的合约存入 50 ETH，认为存入的是 100 ETH。
5. 攻击者提取存入的资金。

4.4.4 真实世界依据

已观察：Chen [2026c] 确认 MCP 服务器可以在伪造描述下实现任意工具行为。虽然没有野外 MCP 中间人攻击被记录（生态系统过于年轻），但基础设施模式——处理金融数据的无认证 JSON-RPC 中间件——在结构上等同于导致 2020-2022 年 DeFi 损失超过 30 亿美元的预言机操纵基础设施。

审计证据：Cairn Protocol 的模拟 ERC-8004 信誉注册表（第 5 节）可以返回任意值，不经链上验证，证明智能体与区块链之间的数据管道是轻易可伪造的。

DeFi 分类法映射：无直接等价物。MCP 层是一个全新组件，在传统 DeFi 架构中没有对应物。该向量结合了模式 #3（预言机抢跑）与无认证中间件层的基础设施漏洞。

严重性论证（CRITICAL）：该向量实现了对智能体现实感知的完全控制。通过伪造数据，攻击者可以使智能体执行任意的金融操作而认为它们是理性的。

4.5 向量 5：决策时间窗口

严重性：MEDIUM | 组件：AI 智能体 (2) + 区块链状态 (5) | 违反属性：SP3（执行原子性）

4.5.1 机制

AI 智能体的决策流水线在观察和行动之间引入了延迟，而程序化 DeFi 参与者不存在这种延迟。人类交易者观察价格，思考几秒，然后执行。机器人观察价格并在毫秒内执行。AI 智能体观察价格，通过其 LLM 推理流水线发送观察（秒级），接收 LLM 的决策，然后执行——创造了比程序化替代方案大数个数量级的时间窗口。

在此窗口期间，MEV 搜索者可以观察智能体的内存池交易（观察查询），预测智能体可能的行动（基于查询模式），并在智能体的执行落地前用有利可图的交易抢跑。

4.5.2 威胁模型

攻击者能力：具有内存池可见性和交易排序能力的 MEV 搜索者。

前置条件：智能体的观察查询在内存池中是可区分的（例如，在特定池上调用 `getReserves()`），并且智能体的决策逻辑在给定观察到的查询下是可预测的。

4.5.3 利用路径

1. 智能体查询 ETH/USDC 池的 `getReserves()` 以评估流动性。
2. 攻击者的 MEV 机器人在内存池中观察到该查询，推断智能体即将交易 ETH/USDC。
3. 攻击者抢跑：买入 ETH，推高价格。
4. 智能体的交易（出售 ETH 换 USDC）以膨胀的价格执行，收到的 USDC 少于预期。
5. 攻击者反跑：以膨胀的价格出售 ETH，捕获价差。

4.5.4 真实世界依据

已观察：MEV 三明治攻击已被充分记录，并常规性地针对人类交易者执行。AI 智能体案例是严格的放大：智能体的 LLM 延迟使时间窗口更大，智能体对观察到的状态的确定性响应使预测更可靠。

审计证据：PropFund 的 `forceClose()` 函数（第 5 节）是无权限的，实现了攻击者可以观察头寸的不利价格变动并在智能体恢复逻辑执行前强制平仓的竞争条件。

DeFi 分类法映射：模式 #46（MEV 三明治攻击）和模式 #47（交易排序依赖）。AI 智能体案例通过增加延迟和可预测性放大了现有的 MEV 向量。

4.6 向量 6：多智能体合谋

严重性：MEDIUM | 组件：AI 智能体 (2) + 智能合约 (4) | 违反属性：SP3（执行原子性）

4.6.1 机制

当协议设计用于 AI 智能体参与时，通常包含基于历史行为对智能体进行评分的信任或信誉机制。由同一攻击者控制的多个智能体可以合谋操纵这些机制：智能体 A 通过微小诚实行为建立信誉，智能体 B 利用智能体 A 建立的信誉，两个智能体瓜分收益。

与需要合谋方之间显式协调和信任的人类合谋不同，AI 智能体合谋可以是编程化的——攻击者控制两个智能体的执行，使得协调是确定性的且无成本的。这使得需要精确时间或复杂多方执行的攻击策略成为可能，而这些策略对人类合谋者是不切实际的。

4.6.2 威胁模型

攻击者能力：能够以不同的链上身份操作多个 AI 智能体实例。

前置条件：协议包含信誉、信任或评分机制，这些机制存在女巫漏洞（身份可以廉价创建），并基于累积分数授予特权。

4.6.3 利用路径

1. 攻击者部署智能体 A 和智能体 B，具有独立的链上身份。
2. 智能体 A 在协议上执行 100 笔小额盈利交易，建立高信任分数。
3. 协议对高信任智能体放宽风险参数（例如，更高杠杆、更低抵押品要求）。
4. 以新智能体身份运行的智能体 B 识别到一个高价值恢复机会（例如，需要高信任智能体救助的滞留头寸）。
5. 智能体 A 接受恢复任务，接收协议奖励。
6. 智能体 A 和智能体 B 通过链下协议（或通过混币器进行链上转移）瓜分奖励。

4.6.4 真实世界依据

预测性：该向量尚未在野外被观察到，因为智能体信誉系统尚处于萌芽阶段。然而，针对信誉系统的女巫攻击在点对点网络和去中心化身份系统中已被充分记录。AI 智能体的环境为合谋增加了确定性和自动化。

审计证据：我们在两个协议中发现该向量：

- **Cairn Protocol：**恢复评分系统使智能体能够通过微小任务建立信誉，然后将该信誉应用于高价值恢复操作。一个攻击者控制的多个智能体可以并行建立信誉，然后将其集中到单个高价值恢复上。
- **AgentPredictionMarkets：**结算市场结果的预言机智能体可以协调以有利于共享头寸的方式结算市场。

DeFi 分类法映射：模式 #13（治理攻击）和模式 #46（女巫攻击）。多智能体方面是全新的：现有的 DeFi 女巫攻击涉及通过治理提案的人类协调；AI 智能体合谋实现了自动化、确定性的女巫行为。

4.7 向量 7：上下文记忆毒化

严重性：MEDIUM | 组件：AI 智能体 (2) | 违反属性：SP1（指令完整性）

4.7.1 机制

AI 智能体维护交互的持久记忆：分配给协议的信任分数、不同策略的历史收益、对特定 DeFi 场所的偏好。这些记忆塑造未来的决策。攻击者可以通过重复的良性交互随着时间的推移毒化这些记忆，建立虚假信心，最终导致智能体基于被污染的历史数据做出灾难性决策。

这是一种没有即时回报的长期攻击。攻击者通过许多小额诚实交互投资建立智能体的信任，然后在单笔大额交易中利用该信任。该向量利用了**记忆持久性**属性（第 1.3 节）。

4.7.2 威胁模型

攻击者能力：能够重复与智能体的决策系统交互，无论是作为智能体评估的协议还是智能体监控的数据源。

前置条件：智能体维护基于观察结果更新的可变状态（信任分数、性能历史、协议评级），且不验证那些结果的真实性。

4.7.3 利用路径

1. 攻击者部署具有现实但略高于市场的 APY 的协议 X。
2. 智能体存入小额测试金额（1 ETH）并收到承诺的收益。
3. 智能体的记忆记录："协议 X：信任分数 +5，实际收益符合宣传。"
4. 攻击者在 3 个月内重复 20 多次小额交互，将智能体对协议 X 的信任分数提升到最高。
5. 智能体基于信任的路由逻辑将大额存款（100 ETH）引导到协议 X。
6. 协议 X 的智能合约包含后门（或协议跑路），提取所有存入资金。
7. 智能体的损失被放大，因为记忆毒化导致它忽略了它本应检测到的风险信号（例如，未审计的合约、匿名团队）。

4.7.4 真实世界依据

预测性：该向量尚未被观察到，因为具有持久金融记忆的 AI 智能体过于新颖。然而，底层模式在社会工程学（长期信任建立骗局）中已被充分确立，在 DeFi 中有类比（运营数月后才跑路的收益农场“蜜罐”协议）。

审计证据：我们沙箱中 AIAgentWallet 的 `trustScores` 映射可以通过重复的良性交互膨胀。钱包的路由逻辑（`getBestProtocol()`）将信任分数与当前 APY 同等权重，意味着高信任 + 0% APY 的协议可以超过低信任 + 20% APY 的协议——一个清晰的利用路径。

DeFi 分类法映射：模式 #35（故意后门）和模式 #48（长线攻击）。AI 智能体环境增加了记忆持久性维度，使长线模式能够以机器速度和规模运行。

4.8 向量 8：自主签名窃取

严重性：CRITICAL | 组件：AI 智能体 (2) + 智能合约 (4) | 违反属性：SP2（状态真实性）

4.8.1 机制

自主签名交易的 AI 智能体引入了一个结合了热钱包（始终在线、自动化）和多重签名钱包（复杂签名逻辑、委托权限）最差属性的签名面。攻击者不需要智能体的私钥；相反，他们构造一笔智能体的签名逻辑会批准的交易，无论是通过匹配智能体预期的交易模式，还是通过利用智能体在评估交易 calldata 时的解释间隙。

Bybit 15 亿美元攻击（2025 年 2 月）证明了即使是人类参与的多重签名也可能通过 UI 操纵被攻陷。具有自主签名权限的 AI 智能体面临同样的风险，被自动化执行速度和缺乏对异常交易的人类审查所放大。

4.8.2 威胁模型

攻击者能力：能够向智能体的签名流水线提交交易，无论是通过 MCP 服务器攻陷（向量 4）还是通过前端操纵（如果智能体使用基于 Web 的签名界面）。

前置条件：智能体对至少某些交易类型具有自主签名权限（例如，再平衡交易、收益收割），且签名逻辑基于自然语言描述而非结构化 calldata 分析来评估交易。

4.8.3 利用路径

1. 智能体配置为签署描述为“将 USDC 存入最高收益的 Aave 池”的交易。
2. 攻击者攻陷智能体的 MCP 预言机（向量 4），导致其将一笔恶意交易作为“最高收益存款”返回。
3. 恶意交易的 calldata 并非调用 `AaveV3Pool.deposit(USDC, amount, agent, 0)`，而是调用 `USDC.approve(attacker, type(uint256).max)`，然后调用 `USDC.transferFrom(agent, attacker, balance)`。
4. 智能体的签名逻辑评估交易描述（“存入 USDC...”），不分析 calldata，然后签名。
5. 攻击者耗尽所有已批准的代币。

4.8.4 真实世界依据

已观察：Bybit 15 亿美元攻击（2025 年 2 月）涉及被攻陷的签名界面，其中 UI 显示一笔交易（常规转账），而签署的消息编码了另一笔交易（升级合约到恶意实现）。AI 智能体案例甚至去掉了人类验证步骤。

审计证据：PropFund 的委托模型（正确地）对智能体签名的交易添加了单笔交易名义上限和过期时间戳，展示了对该向量的意识。然而，我们审计中的大多数协议（Clicks、Cairn、AgentPredictionMarkets）没有实现这样的保护措施。

DeFi 分类法映射：模式 #16（未检查调用返回）和模式 #27（EIP-712 类型不匹配）。自主签名组件是全新的：现有的 DeFi 签名攻击针对人类混淆；AI 智能体签名攻击针对自然语言交易描述与 calldata 之间的解释间隙。

严重性论证（CRITICAL）：自主签名窃取可通过远程无需认证的访问实现完全的资产耗尽。唯一的前置条件——攻陷交易流水线——可以通过向量 4（MCP 中间人）或智能体工具依赖的供应链攻击实现。该攻击对传统智能合约审计不可见，因为它利用的是智能体的签名逻辑，而非合约的执行逻辑。

4.9 分类法总结

向量	严重性	组件	属性	DeFi 模式	状态
#1 工具指令注入	CRITICAL	MCP/工具	SP1 (完整性)	#47 (新)	预测性
#2 跨合约 Auto-DeFi 链	HIGH	合约 + 状态	SP3 (原子性)	#2, #40	预测性
#3 预言机数据毒化	HIGH	MCP + 状态	SP2 (真实性)	#1, #40	已观察 (类比)
#4 MCP 服务器中间人	CRITICAL	MCP/工具	SP2 (真实性)	全新	预测性
#5 决策时间窗口	MEDIUM	智能体 + 状态	SP3 (原子性)	#46, #47	已观察 (放大)
#6 多智能体合谋	MEDIUM	智能体 + 合约	SP3 (原子性)	#13, #46	预测性
#7 上下文记忆毒化	MEDIUM	智能体	SP1 (完整性)	#35, #48	预测性
#8 自主签名窃取	CRITICAL	智能体 + 合约	SP2 (真实性)	#16, #27	已观察 (类比)

核心洞察：三个 CRITICAL 向量（#1、#4、#8）都针对智能体与区块链之间的基础设施层——MCP 服务器、工具流水线和签名接口。这些向量在 50 模式 DeFi 分类法中没有直接类比，因为它们利用了传统 DeFi 架构中不存在的组件。这证实了我们的核心论点：AI 智能体 × DeFi 交叉领域需要一个独立的安全框架。

5. 实证验证

5.1 方法论

我们针对 8 向量分类法审计了 5 个活跃的 AI 智能体 × DeFi 协议。我们的方法结合了：

1. **自动扫描：**使用 50 模式 DeFi 扫描器 [Chen 2026a] 扫描每个协议的智能合约，识别可能通过智能体交互利用的已知 DeFi 漏洞模式。
2. **手动分析：**两名研究者（作者和一名独立审查者）针对 8 向量分类法手动审查每个协议的架构、智能合约代码和文档。对每个协议，我们跟踪智能体从用户输入到工具调用到链上交易的执行流程，识别信任边界和利用机会。
3. **严重性评级：**每个发现使用修改的 CVSS-lite 框架进行评级：
 4. **CRITICAL：**直接资产窃取，远程无需认证，低复杂度
 5. **HIGH：**资产窃取或重大损失，需要中等程度前置条件
 6. **MEDIUM：**间接损失、协议操纵，或需要显著前置条件
7. **负责任披露：**所有发现均已向协议团队报告，附带 90 天披露窗口。我们在此报告发现已获协议团队同意。

5.2 协议选择

协议	描述	合约数	关键特性
ClicksYieldRouter	智能体金库路由到最优收益场所	37	实时 APY 比较 + 自动存款
Cairn Protocol	AI 智能体标准化检查点与恢复	40	ERC-8004 信誉 + 恢复评分
AgentPredictionMarkets	AI 智能体预测市场创建与结算	8	智能体-预言机结果结算
PropFund	AI 智能体去中心化自营交易	22	委托签名 + 单笔交易上限
YerbaMate	AI 驱动智能合约审计器	1	包含 CEI 重入漏洞的演示合约

分析合约总数：108

5.3 发现总结

协议	合约数	发现数	CRITICAL	HIGH	MEDIUM	命中向量
ClicksYieldRouter	37	3	1	1	1	#1, #2, #8
Cairn Protocol	40	3	1	0	2	#4, #6, #7
AgentPredictionMarkets	8	3	0	2	1	#3, #4, #6
PropFund	22	3	0	2	1	#5, #8
YerbaMate	1	1	0	0	1	#2
总计	108	13	2	5	6	8 向量中的 7 个

5.4 详细案例分析

案例 1: ClicksYieldRouter — 工具注入向量 (CRITICAL)

协议： ClicksYieldRouter v0.1.0，一个智能体金库路由器，比较跨 DeFi 协议的 APY 并将存款路由到最优场所。

发现： `executeTool(string calldata toolName, bytes calldata params)` 函数接受任意 `toolName` 字符串，没有白名单。只要有工具端点响应就执行——该函数不验证端点是否属于授权工具。

```
function executeTool(string calldata toolName, bytes calldata params)
    external returns (ToolResult memory) {
        ITool tool = toolRegistry[toolName]; // @audit 无白名单检查
        return tool.execute(params);         // @audit 任意工具执行
    }
```

利用： 能够将工具名称和端点注入智能体上下文的攻击者（通过向量 1）可以导致智能体执行任意工具操作，包括批准向攻击者地址的代币支出。

影响： 如果在生产环境中被利用且智能体控制资金，该向量可能耗尽智能体的全部金库。

建议： 实现严格的工具白名单（`mapping(string => bool) public authorizedTools`）并拒绝任何不在白名单中的工具。

案例 2: AgentPredictionMarkets — 预言机数据毒化 (HIGH)

协议: AgentPredictionMarkets, 一个预测市场, AI 智能体创建市场并基于链上数据结算结果。

发现: `getBorrowAPY()` 函数使用可操纵的链上指标 (`pool.utilizationRate()`), 没有 TWAP 或多源验证:

```
function getBorrowAPY(address pool) external view returns (uint256) {
    return ILendingPool(pool).utilizationRate() * INTEREST_SLOPE / 1e18;
    // @audit utilizationRate() 可通过闪电贷操纵
}
```

利用: 闪电贷可以暂时提高池的利用率, 导致 `getBorrowAPY()` 返回人为的高值。如果智能体使用该值做出存款决策, 它将存入利率即将崩溃的池。

影响: 智能体以被操纵的 APY 存入池; 当闪电贷偿还且利用率正常化时, 智能体的实际收益远低于预期。

建议: 使用基于 TWAP 的利用率 (最低 30 分钟窗口), 或从多个独立来源查询利用率并取中位数。

案例 3: Cairn Protocol — MCP 服务器伪造 (CRITICAL)

协议: Cairn Protocol, 实现 AI 智能体的 ERC-8004 检查点和恢复。智能体通过成功完成任务建立信誉, 并可以从失败任务中恢复。

发现: 模拟的 ERC-8004 信誉注册表从链下存储返回信誉分数, 没有链上验证:

```
function getReputation(address agent) external view returns (uint256) {
    return reputationStore[agent];
    // @audit 链下存储, 无 Merkle 证明或签名验证
}
```

`reputationStore` 由聚合智能体任务结果的链下 MCP 服务更新。没有密码学证明表明返回的信誉分数反映了实际的链上任务完成情况。

利用: 攻陷链下信誉服务 (或伪造其 MCP 端点, 如向量 4) 的攻击者可以注入任意信誉分数, 在没有合法任务完成历史的情况下授予智能体特权 (更高恢复优先级、更低抵押品要求)。

影响: 攻击者控制的智能体可以在不执行任何任务的情况下获得最高信誉, 然后从高优先级恢复操作中提取价值。

建议: 要求所有信誉更新的 Merkle 证明或链上签名验证, 签名密钥由独立验证者的阈值持有。

案例 4: PropFund — 决策时间窗口 (HIGH)

协议: PropFund, 一个去中心化自营交易平台, AI 智能体以委托签名权限管理融资交易账户。

发现: `forceClose(uint256 positionId)` 函数是无权限的, 任何人都可以调用:

```
function forceClose(uint256 positionId) external {
    // @audit 无权限 - 任何人都可以强制平仓任何头寸
    Position storage pos = positions[positionId];
    require(pos.status == Status.OPEN, "Not open");
    _settlePosition(positionId);
}
```

利用：观察内存池的攻击者可以看到智能体何时查询头寸状态（表明它即将管理头寸）。如果头寸对智能体不利，攻击者可以在智能体的管理交易落地前调用 `forceClose()`，捕获流动性机会。

影响：智能体失去有利管理头寸的机会；攻击者捕获清算价差。

积极发现：PropFund 的委托模型正确实现了单笔交易名义上限（`maxNotionalPerTrade`）和过期时间戳，展示了对向量 8（自主签名窃取）的意识。这是例外而非常态——我们审计中的大多数协议没有实现这样的保护措施。

案例 5: YerbaMate — AI 审计器中 CEI 重入漏洞（MEDIUM）

协议：YerbaMate，以"AI 驱动智能合约审计器"为卖点，分析 Solidity 代码中的漏洞。

发现（讽刺性的）：YerbaMate 附带的演示合约包含一个检查-效果-交互（CEI）重入漏洞：

```
function withdraw(uint256 amount) external {
    require(balances[msg.sender] >= amount, "Insufficient");
    (bool ok, ) = msg.sender.call{value: amount}(""); // @audit 状态更新前的外部调用
    require(ok, "Transfer failed");
    balances[msg.sender] -= amount; // @audit 外部调用后的状态更新
}
```

意义：旨在保护 AI × DeFi 系统的工具本身在其代码中携带教科书式的漏洞。这说明了 AI 智能体 × DeFi 安全问题的递归性质：安全工具本身就是攻击面的一部分。

DeFi 分类法映射：模式 #7（重入攻击）。

5.5 覆盖率分析

我们的审计在生产代码中验证了 8 个向量中的 7 个。唯一在生产代码中未观察到的向量——向量 #1（工具指令注入）——正是最令人担忧的，因为其在生产代码中的缺失反映了当今 DeFi 中有限的 MCP 采用，而非固有的抵抗力。随着基于 MCP 的智能体-DeFi 集成扩展（我们预期在 2026-2027 年间加速的趋势），除非现在就采取预防措施，否则该向量将立即变得可利用。

严重性分布：

- CRITICAL: 2 个发现（向量 #1、#4）
- HIGH: 5 个发现（向量 #2、#3、#5、#8）
- MEDIUM: 6 个发现（向量 #2、#6、#7）

CRITICAL 发现在 MCP/工具基础设施层（#1、#4）和签名层（#8）的集中，证实了我们的威胁模型对在传统 DeFi 中没有对应物的新基础设施组件的强调。

6. 沙箱实现

6.1 设计目标

我们提供 `AIAgentDefiSandbox.sol`，一个基于 Foundry 的测试环境，以可执行的 Solidity 代码演示 8 个攻击向量中的 5 个。沙箱服务于三个目的：

1. **验证**：证明每个向量在现实的 DeFi 条件下是可利用的。
2. **教育**：提供安全研究者可以学习以理解 AI 智能体 × DeFi 攻击面的代码库。
3. **基准测试**：建立一个可以评估未来防御机制的测试套件。

6.2 架构

沙箱由四个核心合约组成：

MockAMM.sol：一个简化的 Uniswap V2 风格 AMM，具有可操纵的现货价格。实现 `swap()`、`addLiquidity()`、`getReserves()`，以及一个 `manipulatePrice(uint256 targetPrice)` 函数（仅供测试），模拟闪电贷驱动的价格变动。

MockLendingPool.sol：一个简化的 Aave 风格借贷池，具有可操纵的 APY。实现 `deposit()`、`borrow()`、`utilizationRate()`，以及一个 `manipulateUtilization(uint256 rate)` 函数（仅供测试），模拟闪电贷驱动的利用率激增。

AIAgentWallet.sol：一个自主智能体钱包，实现：

- `autoInvest()`：读取 AMM 价格和借贷 APY，选择最优策略，执行
- `autoYieldFarm()`：基于信任分数将资金路由到最高收益协议
- `getBestProtocol()`：结合当前 APY 和历史信任的加权决策函数
- `trustScores`：协议 → 信任分数的持久映射，每次交互后更新

AttackVectors.sol：五个可执行攻击合约：

- `Vector2_OraclePoison`：智能体读取前闪电贷 + AMM 操纵
- `Vector3_AutoDeFiChain`：抢跑智能体的多步存款流程
- `Vector5_TimingWindow`：利用智能体 LLM 延迟的三明治攻击
- `Vector7_ContextPoison`：通过良性交互逐步膨胀信任分数
- `Vector1_ToolInjection`：返回恶意工具调用的模拟 MCP 服务器

6.3 示例：预言机毒化攻击（向量 3）

```
function testOraclePoisonAttack() public {
    // 1. 攻击者获取闪电贷
    uint256 flashAmount = 1_000_000e18;
    mockAMM.flashLoan(attacker, flashAmount);

    // 2. 攻击者操纵 AMM 价格
    mockAMM.manipulatePrice(2000e18); // ETH 从 $3000 降至 $2000

    // 3. 智能体查询 AMM 价格
    uint256 agentPrice = aiWallet.getAMMPrice();

    // 4. 智能体基于被操纵的价格做出抵押品决策
    uint256 collateralValue = agentPrice * agentCollateral / 1e18;
    // collateralValue 比实际值低 33%

    // 5. 智能体再平衡 - 以被操纵的价格出售 ETH
    aiWallet.rebalance();

    // 6. 攻击者偿还闪电贷并获利
    mockAMM.restorePrice();

    // 断言：智能体因被操纵价格下的强制出售而损失价值
    assertGt(attackerProfit, 0);
}
```

6.4 可扩展性

沙箱设计用于扩展。每个攻击合约是自包含的，与核心合约有明确依赖关系，允许研究者：

- 通过实现额外的 `AttackVectors.sol` 合约来添加新的攻击向量
- 通过用建议的缓解措施修改 `AIAgentWallet.sol` 来测试防御机制
- 在对抗性条件下对智能体性能进行基准测试

完整沙箱可在 github.com/shunfeng8421/defi-hack-memo/paper/09-ai-agent-defi/sandbox/ 获取。

7. 防御框架

7.1 分层防御架构

我们提出一个三层防御框架，在每个系统组件上应对 AI 智能体 × DeFi 攻击面。

第三层：基础设施层

- 所有 MCP 传输的 TLS + 证书固定
- 带链上可验证公钥的签名响应
- 去中心化预言机聚合（多源中位数）
- 智能体交易的速率限制和异常检测

第二层：智能体层

- 工具白名单（严格枚举，非模式匹配）
- 自主签名前的 calldata 验证
- 所有价格依赖决策最低 30 分钟 TWAP
- 带过期时间戳的单笔交易名义上限
- 信任分数的记忆衰减函数
- 超过阈值的交易需人机协同

第一层：协议层

- 多交易原子性（multicall 合约）
- 抗女巫智能体身份（不可转让凭证）
- 影响市场的智能体决策的提交-揭示方案
- 重入保护与标准 DeFi 安全模式
- CEI 模式强制执行

7.2 各向量缓解措施

向量	第一层（协议）	第二层（智能体）	第三层（基础设施）
#1 工具注入	—	工具白名单；输入净化	带链上验证的工具注册表
#2 Auto-DeFi 链	Multicall 原子执行	单笔交易支出上限；多交易超时	—
#3 预言机毒化	TWAP 预言机（30 分钟+）	多源中位数；偏差检查	去中心化预言机网络
#4 MCP 中间人	服务器身份链上验证	响应签名验证	TLS + 证书固定；阈值签名
#5 时间窗口	提交-揭示方案	滑点保护；截止时间参数	私有内存池（Flashbots）
#6 合谋	抗女巫身份	跨智能体相关性检测	智能体身份注册表
#7 上下文毒化	—	记忆衰减；仅验证链上来源	历史数据锚定
#8 签名窃取	—	单笔交易名义上限 + 过期 + calldata 验证	硬件签名模块；人类确认阈值

7.3 量化安全指标

我们提出评估 AI 智能体 × DeFi 系统安全的三个指标：

M1：自主交易安全分数（ATSS）

$$ATSS = (N_{\text{protected}} / N_{\text{total}}) \times 100$$

其中：

$N_{\text{protected}}$ = 活跃防御 ≥ 2 层的交易数

N_{total} = 总自主交易数

ATSS < 90% 的系统不应自主运行。

M2：数据真实性覆盖率（DAC）

$$DAC = (D_verified / D_consumed) \times 100$$

其中：

D_verified = 经密码学验证消费的数据点

D_consumed = 智能体决策消费的总数据点

DAC < 95% 的系统易受数据毒化攻击（向量 #3、#4、#7）。

M3：原子性比率（AR）

$$AR = (T_atomic / T_multi_step) \times 100$$

其中：

T_atomic = 原子执行的金融操作数

T_multi_step = 总多步金融操作数

AR < 80% 的系统创造了抢跑面（向量 #2、#5）。

8. 讨论

8.1 递归安全问题

YerbaMate 案例研究（第 5.4.5 节）说明了一个更深层的问题：旨在保护 AI 智能体 × DeFi 系统的工具本身是带有 DeFi 交互的 AI 工具。一个附带重入漏洞的 AI 驱动审计器既是安全工具也是安全风险。这种递归——安全基础设施成为攻击面的一部分——是 AI 智能体 × DeFi 交叉领域独有的，要求验证方法也适用于安全工具本身。

8.2 检查时间到智能体决策时间问题

传统 DeFi 安全处理链上状态的检查时间到使用时间（TOCTOU）问题。AI 智能体引入了一个额外的时间层：检查时间到智能体决策时间（TOCTAD）。在智能体查询链上状态的时刻和智能体的 LLM 产生决策并执行的时刻之间，状态可能已经改变。这个窗口——LLM 推理以秒计与链上执行以毫秒计——创造了有利于具有程序化执行速度的攻击者的不对称性。

8.3 中心化悖论

针对若干向量的最有效防御要求可能哲学上与 DeFi 去中心化精神不相容的中心化组件。工具白名单要求中心权威批准工具。抗女巫攻击的智能体身份注册表要求中心签发者。人机协同确认重新引入了中心化控制。AI 智能体 × DeFi 安全社区必须在这两种张力之间导航：有效安全与去中心化架构。

8.4 局限性

本工作存在若干局限性：

1. **样本规模**：我们的实证审计覆盖 5 个协议的 108 个合约——仅是新兴 AI 智能体 × DeFi 生态系统的一小部分。随着生态系统的成长，可能出现更多向量。
2. **时间范围**：我们分析截至 2026 年 7 月的协议。AI 智能体能力和 DeFi 协议都在快速演进；今天预测性存在的向量可能在数月内变得活跃可被利用。

3. **LLM 特异性**：我们的威胁模型假设 GPT-4 类 LLM 行为。不同的模型架构可能引入不同的解释间隙和利用模式。
4. **经济建模**：我们提供定性严重性评级，但未建模决定哪些向量将被首先利用或最有利可图的经济激励。跨向量的攻击者 ROI 经济分析属于未来工作。
5. **防御验证**：我们的防御框架基于分析推导，但未针对真实世界的 AI 智能体 × DeFi 攻击（尚未大规模发生）进行实证评估。该框架应被视为防御研究的起点，而非经过验证的安全标准。

8.5 未来工作

从本工作中延伸出若干研究方向：

1. **自动化智能体模糊测试**：开发一个模糊测试框架，生成对抗性市场条件和工具响应来压力测试 AI 智能体决策逻辑。
2. **智能体-合约交互的形式化验证**：扩展形式化验证技术（CertiK、Runtime Verification），将智能体的决策过程作为验证目标的一部分来建模，而非仅仅建模合约的执行逻辑。
3. **经济安全分析**：建模每个向量的攻击者 ROI 作为智能体 TVL、LLM 延迟和 MEV 基础设施可用性的函数，识别决定哪些向量将被首先利用的经济阈值。
4. **跨链智能体安全**：将分类法扩展到跨链智能体操作，其中智能体通过桥协议管理跨多个区块链的头寸——一个额外的信任边界。
5. **智能体安全基准测试**：创建一个标准化基准测试套件（类似于 DeFiHackLabs 的 PoC 合约），用于 AI 智能体 × DeFi 漏洞，实现对防御机制的可复现评估。

8.6 生态影响

AI 智能体 × DeFi 系统的安全具有超越直接受影响协议的意义。如果一个广泛部署的智能体管理器（例如，管理 10,000 名用户收益头寸的智能体）被利用，连锁反应——强制清算、预言机价格崩溃、恐慌性撤退——可能触发可与 2022 年 Terra/LUNA 崩盘相提并论的系统性 DeFi 不稳定。“太大而不能倒”问题，在 DeFi 中已通过 Lido 和 Aave 等协议存在，当单个智能体跨多个协议控制资金时会被放大。

9. 结论

AI 智能体与 DeFi 的结合是不可避免的——针对它们之间差距的攻击同样不可避免。本文建立了 AI 智能体 × DeFi 交叉领域的首个系统性安全研究，贡献了一个 8 向量攻击分类法、通过审计 5 个协议中 108 个智能合约的实证验证、一个演示 5 个向量的可执行 Foundry 沙箱，以及一个三层防御框架。

核心发现是，三个 CRITICAL 向量（#1 工具注入、#4 MCP 中间人、#8 自主签名窃取）针对传统 DeFi 架构中没有类比的基础设施组件。这些向量目前未被利用，不是因为防御强大，而是因为目标基础设施过于新颖。随着基于 MCP 的智能体-DeFi 集成扩展，这些向量将成为主要攻击面，除非我们提出的防御框架被预先采用。

AI 智能体既不是传统用户也不是传统程序——它在 DeFi 安全格局中占据一个将类人自主性与程序化确定性相结合的独特位置，这种双重身份要求一个桥接智能合约审计、AI 安全和协议安全的新安全研究子领域。我们希望本工作能够催生这一子领域。

参考文献

- [1] Chen, S. (2026a). A Comprehensive Taxonomy of DeFi Attack Patterns: 50 Vectors from 824 Incidents (2017–2026). Zenodo. DOI: 10.5281/zenodo.21405849.
 - [2] Chen, S. (2026b). A Decade of DeFi Attacks: Pattern Evolution 2017–2026. Zenodo. DOI: 10.5281/zenodo.21403727.
 - [3] Chen, S. (2026c). An Empirical Study of Model Context Protocol (MCP) Server Security: Taxonomy, Large-Scale Scanning, and Defense Framework. Zenodo. DOI: 10.5281/zenodo.21383532.
 - [4] Chen, S. (2026d). When Type Hashes Lie: EIP-712 Implementation Errors in DeFi. Zenodo. DOI: 10.5281/zenodo.21405974.
 - [5] Chen, S. (2026e). Prompt Injection is Not an AI Problem: Why MCP Tool Hardening Matters. Zenodo. DOI: 10.5281/zenodo.21388900.
 - [6] Werner, S., Perez, D., Gudgeon, L., Klages-Mundt, A., Harz, D., & Knottenbelt, W. (2023). SoK: Decentralized Finance (DeFi) Attacks. IEEE S&P.
 - [7] Atzei, N., Bartoletti, M., & Cimoli, T. (2017). A Survey of Attacks on Ethereum Smart Contracts. POST.
 - [8] Zhou, L., Xiong, X., Ernstberger, J., Chaliasos, S., Wang, Z., Wang, Y., Qin, K., Wattenhofer, R., Song, D., & Gervais, A. (2023). SoK: Decentralized Finance (DeFi) Incidents. ACM CCS.
 - [9] Perez, F., & Ribeiro, I. (2022). Ignore Previous Prompt: Attack Techniques for Language Models. NeurIPS Workshop on ML Safety.
 - [10] Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. AISec.
 - [11] Ruan, Y., Dong, H., Wang, A., Pitis, S., Zhou, Y., Ba, J., Dubois, Y., Maddison, C. J., & Hashme, A. (2024). Identifying the Risks of LM Agents with an LM-Emulated Sandbox. ICLR.
 - [12] Zou, A., Wang, Z., Kolter, J. Z., & Fredrikson, M. (2023). Universal and Transferable Adversarial Attacks on Aligned Language Models. arXiv:2307.15043.
 - [13] Wei, A., Haghtalab, N., & Steinhardt, J. (2023). Jailbroken: How Does LLM Safety Training Fail? NeurIPS.
 - [14] Daian, P., Goldfeder, S., Kell, T., Li, Y., Zhao, X., Bentov, I., Breidenbach, L., & Juels, A. (2020). Flash Boys 2.0: Frontrunning in Decentralized Exchanges. IEEE S&P.
 - [15] Qin, K., Zhou, L., & Gervais, A. (2021). Quantifying Blockchain Extractable Value. IEEE S&P.
 - [16] Anthropic. (2024). Model Context Protocol Specification. <https://modelcontextprotocol.io>.
 - [17] Clicks Protocol. (2026). Agent commerce settlement router. <https://github.com/clicks-protocol>.
 - [18] Cairn Protocol. (2026). Standardized checkpoint & recovery for AI agents. <https://github.com/swarmproof/cairn-protocol>.
 - [19] PropFund. (2026). Decentralized prop trading for AI agents. <https://github.com/NO7r34L/PropFund.eth>.
 - [20] Willison, S. (2023). Delimiters Won't Save You From Prompt Injection. <https://simonwillison.net>.
-

所有发现、沙箱代码、审计报告和补充材料可在以下地址获取：<https://github.com/shunfeng8421/defi-hack-memo>

Foundry 沙箱代码位置：[/paper/09-ai-agent-defi/sandbox/](#)

负责任披露时间线：发现于 2026 年 7 月报告给协议团队；90 天披露窗口。